# Health ID: DevOps runbook (AWS)

Prepared 2 November 2026 for the DevOps engineer. Owner: D-Eminence. AWS account `659225405023`, region `eu-west-1`.
The full detail is in `infra/DEVOPS_HANDOVER.md` on the `dev` branch of **D-Eminence/hid-system**. Section numbers below refer to that file.

**Contents**


1. Rules for every change
2. Do now, apply 1: document upload (CORS)
3. Do now, apply 2: phone and computer notifications (web push)
4. Read-only checks to send back now
5. AWS settings for document reading (OCR)
6. Secrets only the owner creates
7. Coming next: don't apply yet
8. Release reminders
9. What to send back after each step


## 1. Rules for every change

- Use the guarded helper from section 4 every time: **plan**, review the private manifest, then **apply** with `--accepted-review-sha256 "<sha256>"`.
- Don't start a backend release between a plan and its apply. Never run a website release and a backend release at the same time. Check with the owner that nothing is releasing before you plan.
- Keep plans and review manifests private and out of Git. Remove `TF_VAR_cloudflare_origin_secret` from your shell after each session.
- Don't rename or delete anything with "staging" in its name. Those are **live production resources**: `hid-staging-*` buckets, `/hid/staging/*` secrets and log groups.
- Never put a private key or password in Git, tfvars, a ticket, chat or a command line.
- Confirm the account first: `aws sts get-caller-identity` must show `659225405023`. The state backend and lineage are in section 4. Stop if they differ.
- If a plan shows anything different from what's described here, **stop** and send the owner the plan summary before you apply.

Helper commands (section 4, from `infra/terraform` after `terraform init` as written there):

```
python scripts/production_release_infrastructure.py plan  --var-file
environments/production.tfvars --manifest private-release-review.json
python scripts/production_release_infrastructure.py apply --var-file
environments/production.tfvars --manifest private-release-review.json --accepted-review-sha256
"<reviewed manifest SHA256>"
```

## DO NOW 2. Apply 1: document upload (CORS)

Section 4, "Document upload (CORS)". Without this, every document upload from the clinic pages fails. It's already merged into `dev`. Do it as an apply of its own, before web push.

1. **Read the live rule (read-only):**

   ```
   aws s3api get-bucket-cors --bucket <documents bucket name> --region eu-west-1
   ```

   The bucket is the retained `hid-staging-documents-*` bucket (`module.data.aws_s3_bucket.documents`). If you get anything other than `NoSuchCORSConfiguration`, send it to the owner first, because Terraform will replace it.
2. **Plan from `dev`.** The new resource is `module.data.aws_s3_bucket_cors_configuration.documents[0]` (1 to add). It allows PUT only, from app., ehr., lab., pharmacy. and migrate.

3. **Expect other dev changes in the same plan.** If the cost changes the owner approved on 1 November (section 4, "Monitoring cost" and "AWS cost") aren't applied yet, they appear here too:

| Change | Resources | Action |
|---|---|---|
| Monitoring cost | ECS cluster + 12 running-task alarms | 13 updated in place |
| Bedrock endpoint in one zone | `module.ai[0].aws_vpc_endpoint.bedrock_runtime` | 1 updated in place |
| ECR clean-up | 12 ECR lifecycle policies | 12 replaced (provider can't edit them) |
| Worker scaling on dead metrics | 2 autoscaling policies | 2 destroyed |
| Alerts from production alarms | alerts KMS key + SNS topic policy | 2 updated in place |

   With all of these plus CORS, expect **Plan: 13 to add, 16 to change, 14 to destroy**. Before applying the alarm change, do the read-only dry run of the new alarms that section 4 describes. New task-definition revisions with the **same images** may also appear: they restart those services. Anything else, especially a database, bucket, key, network or image replacement: **stop** and send the summary.
4. **Apply** with the reviewed SHA256.
5. **Check:** at Demo Hospital, upload a fictional document (Consultation → Documents → Upload document). It should succeed.

---

## DO NOW 3. Apply 2: phone and computer notifications (web push)

Section 4, "Web push (B6)". Do this after apply 1, as a separate apply.

0. OWNER **Steps 0–1, the owner only.** The owner generates the key pair on their own computer (the command is in section 4). They add the 43-character private key as `webPushVapidPrivateKey` in `/hid/staging/notification-provider` (Secrets Manager, eu-west-1), changing nothing else. Then they send DevOps the **public** key only.
1. **Step 2:** in a reviewed commit on `dev`, replace the commented web push block in `environments/production.tfvars` with:

```
web_push_enabled          = true
web_push_vapid_public_key = "<the 87-character public key the owner sends>"
web_push_subject          = "mailto:support@healthidentitydirectory.com"
```

2. **Step 3:** plan, then apply. The plan should only replace the task definitions of `identity-api` and `notification-api` and update those two services in place, with **no image change**.
3. **Step 4, check names only** (the loop is in section 4):
   - `notification-api` shows `WEB_PUSH_VAPID_PUBLIC_KEY`, `WEB_PUSH_SUBJECT` and the secret `WEB_PUSH_VAPID_PRIVATE_KEY`.
   - `identity-api` shows the two environment names only.
   - CloudWatch `/hid/staging/notification-api` and `/hid/staging/identity-api` both log `Web push is on (keyId=...)` with the same key id.

To switch it off: commit `web_push_enabled = false`, plan and apply. Remove the private key from the secret only after that apply. Rotate the keys only if the private key is ever exposed.

## READ-ONLY 4. Checks to run now and send back

### a) Before the virus scanner

```
aws guardduty list-malware-protection-plans --region eu-west-1
aws s3api get-bucket-notification-configuration --bucket <documents bucket name> --region eu-west-1
aws events list-rules --name-prefix DO-NOT-DELETE-AmazonGuardDutyMalwareProtectionS3 --region eu-
west-1
aws lambda get-account-settings --region eu-west-1 --query AccountLimit
```

**Expected:** no protection plan, an empty notification configuration, no rule, and `UnreservedConcurrentExecutions` of **102 or more**. If that number is lower, open an AWS quota increase request now, because it can take days.

### b) Account safety (added)

```
aws rds describe-db-instances --region eu-west-1 --query "DBInstances[].
{id:DBInstanceIdentifier,deletionProtection:DeletionProtection,backupDays:BackupRetentionPeriod,encr
ypted:StorageEncrypted,multiAZ:MultiAZ}"
aws s3api get-bucket-versioning     --bucket <documents bucket name>
aws s3api get-bucket-encryption     --bucket <documents bucket name>
aws s3api get-public-access-block   --bucket <documents bucket name>
aws cloudtrail describe-trails --query "trailList[].{name:Name,multiRegion:IsMultiRegionTrail}"
aws guardduty list-detectors --region eu-west-1
aws iam get-account-summary --query "SummaryMap.AccountMFAEnabled"
aws budgets describe-budgets --account-id 659225405023 --query "Budgets[].
{name:BudgetName,limit:BudgetLimit.Amount}"
```

**Expected:**

- The database has deletion protection on, backups kept 7 days or more, and encrypted storage.
- The documents bucket has versioning on, default encryption, and all four public-access blocks set to true.
- A CloudTrail trail exists.
- Root MFA is on (the summary shows 1).
- A monthly budget of USD 400 exists with alerts. If it doesn't, say so in your reply. Once the owner confirms, create it with email alerts to the owner at 80% and 100%, actual and forecast.

Send back anything that differs. Change nothing in this step; the budget, if it's missing, comes after the owner confirms.

## 5. AWS settings for document reading (OCR)

The AI step of document reading **no longer runs on AWS**, so skip everything about Bedrock for it. Don't turn on Bedrock model access or add Bedrock permissions for OCR, and don't check Bedrock calls in CloudTrail for it.

1. **Textract permission:** give the role that will run document reading only `textract:DetectDocumentText`, in eu-west-1.
2. **AI opt-out:** set an AWS Organizations AI services opt-out policy (opt out of all services), so AWS doesn't keep document content to improve Textract or its other AI services. This is done in the management account: Organizations → Policies → AI services opt-out policies. Attach it to the root and confirm it shows as effective on account `659225405023`. If the account isn't in an AWS Organization, tell the owner first: opt-out policies need one.
3. **Test documents only:** use fictional test documents until the owner says otherwise.

> **Leave the patient chat's Bedrock setup exactly as it is.** That means the private Bedrock connection, the EHR service's Bedrock permissions and the Titan embedding model. The chat uses them today.

## OWNER ONLY 6. Secrets the owner creates (never through DevOps chat or tickets)

- **Web push keys:** section 3, steps 0–1.
- **Offline backup key**, needed before the offline-mode escrow (hid-system#133). On the owner's own computer, with Node 22:

  ```
  node -e
  "console.log(JSON.stringify({'1':require('node:crypto').randomBytes(32).toString('base64url')}))"
  ```

  In Secrets Manager, eu-west-1, create the secret `/hid/staging/offline-escrow`:

  - type "Other type of secret", with the key `offlineEscrowKeys` and the printed JSON as its value;
  - encryption key `aws/secretsmanager`;
  - no automatic rotation.

  The owner sends DevOps the secret's **ARN** only. Offline backup stays off until the offline EHR version is released.
- **Cloudflare origin secret:** read it from `/hid/staging/cloudflare-origin` only for a plan or apply, and unset it afterwards (section 4).

## NEXT 7. Coming next: don't apply until the owner sends the PR link

These aren't merged yet. **The order matters.**

1. **Raise the service-to-service caller limit from 6 to 8**, in an apply of its own. If more callers are configured than the limit allows, every service-to-service token stops. So the limit always goes up first, in a separate apply, before any new caller arrives.
2. **Virus scanner** (GuardDuty Malware Protection for S3), in five stages, each its own reviewed commit and apply:
   1. backend release;
   2. the caller limit above;
   3. GuardDuty and the bridge in observe mode;
   4. backfill, then reconcile;
   5. tag enforcement, only after the stage 4 check passes.

   It costs about USD 2.5–3.5 a month, plus about USD 0.40 once for the backfill.
3. **Support chat Health ID check:** `support-api` becomes the 8th caller. Apply it only after item 1.
4. **Offline mode key escrow** (D-Eminence/hid-system#133): apply it only after the new `ehr-api` image is live and the owner has created `/hid/staging/offline-escrow` (section 6).

## 8. Release reminders

- Merging to **health** `main` releases the website to production. Merging to **hid-system** `staging-novu-ci-20261005` releases the backend. Only one runs at a time, and none runs between a Terraform plan and its apply.
- A re-run of a failed website release can build but can't deploy. Start a fresh run of the `production-frontends` workflow on `main` instead.
- If the public site build fails while fetching Google Fonts, it's a network blip. Start a fresh run.
- Every backend release is followed by the website's backend pins being updated (owner-approved). DevOps doesn't need to act on it, but shouldn't apply Terraform while it runs.

## 9. What to send back after each step

- The plan summary: resource names and counts, no secret values.
- The SHA256 you applied.
- The result of the check.

**Order for this week:**

1. Section 4 read-only checks (send them back).
2. Apply 1 (CORS, plus any pending cost changes).
3. The owner creates the web push keys.
4. Apply 2 (web push).
5. OCR account settings (section 5).
6. Wait for the PR links for section 7.